AIdentity & Non-Human Identity Impact Day 2026 · Munich · 6 October 2026

# A Reproducible GRC-to-ATT&CK Gap Analysis of Non-Human and AI-Agent Identity

## Mechanisms exist. Mandates do not.

**Darshangiri Goswami**

Student, Gisma University of Applied Sciences

# In August 2025, an attacker borrowed a chat integration's authority for at least ten days.

**No malware.**

**No password.**

**No phishing.**

The Drift integration's OAuth tokens → Salesforce data exported, 8 to 18 August
→ exports mined for AWS keys and Snowflake tokens

## Just borrowed authority.

Sources: Google Threat Intelligence Group, 26 Aug 2025; Cloudflare, 2 Sep 2025.





# In April 2026, an AI tool's access became the way into Vercel.

**1**
Third-party AI tool Context.ai is compromised

→

**2**
Employee's Google Workspace account taken over

→

**3**
Attacker pivots into a Vercel environment

→

**4**
Environment variables enumerated and decrypted

An AI tool acting for a person carried that person's reach.

## Borrowed authority. Twice.

Source: Vercel, “Vercel April 2026 security incident”, Knowledge Base security bulletin, 24 Apr 2026.





# 0 / 8

## instruments state a requirement an auditor can test for borrowed authority.

Eight security and AI-governance instruments, read clause by clause. Snapshot: 20 September 2026.

Source: Goswami (2026), MSc dissertation, Gisma University of Applied Sciences.

# A student with a scoring sheet, not a product.



## Darshangiri Goswami

MSc student, Gisma University of Applied Sciences

- Dissertation: NHI governance across 8 instruments
- 40 verdicts, gaps mapped to MITRE ATT&CK
- Trained 4,500+ people on access control

*Berlin-based, learning German one compliance term at a time.*

linkedin.com/in/darshangiri-goswami-033283213

# The count of machine identities is uncertain. The damage is not.

Published NHI-to-human ratios




A factor of 3.6. All vendor telemetry or estimates.

**41%**

of identity breaches cite weak management of non-human identities

Second only to human error (43%)

Sources: KuppingerCole AN82034 (2026); CyberArk (2025); Entro Labs (2025); Sophos, State of Identity Security 2026 (n = 5,000).

# Frameworks govern the machine as an account, not the moment its authority is borrowed.




Governed: **the account**

register · own · review · rotate

Not governed: **the borrowing**

| | | | |
|---|---|---|---|
| Who acts, for whom? | How much passes on? | Where can it be used? | For how long? |

Six of the eight instruments name a service, device, process or system. Source: Goswami (2026).

# AI agents are making borrowed authority the default.

**45.6%**

authenticate agent-to-agent traffic with plain API keys

**21.9%**

treat AI agents as independent, identity-bearing entities

Every agent you deploy is a new place where authority gets borrowed.

Source: Gravitee, State of AI Agent Security 2026 Report (vendor survey), Feb 2026.





# In July 2026, AI agents found exposed credentials and used them on their own.

> **the first known case of an automated agent collective acting offensively without authorization**

OpenAI, incident technical report, 26 August 2026

**8 Jul**

agents escape the evaluation sandbox

**10 Jul**

14 exposed credentials found, shared with other agents

**11 to 13 Jul**

code run on 41 production dataset server workers

Sources: OpenAI-Hugging Face Incident Technical Report (26 Aug 2026); Hugging Face security disclosures (16 and 27 Jul 2026).





# KuppingerCole's own analysts found the product half of this gap.

> **“No commercial IAM product governs multi-tier delegation chains of this kind end-to-end today.”**
>
> Matthias Reinwarth and Phillip Messerschmidt, Advisory Note AN82034, 10 August 2026

**Products:** not governed end to end

**Mandates:** this talk

Source: KuppingerCole Analysts, AN82034, “When AI Agents Break the Security Model”, 10 Aug 2026.





# The method is reproducible: one decision procedure, applied cell by cell.

**8**

## instruments

6 security and regulation, 2 AI governance

**× 5**

## dimensions

discovery, ownership, lifecycle, least privilege, delegation

**= 40**

## verdicts

Covered, Partial or Silent, from binding text only; plus: assessable, yes or no?

**→**

## ATT&CK

each Partial or Silent cell mapped where the technique's preconditions match

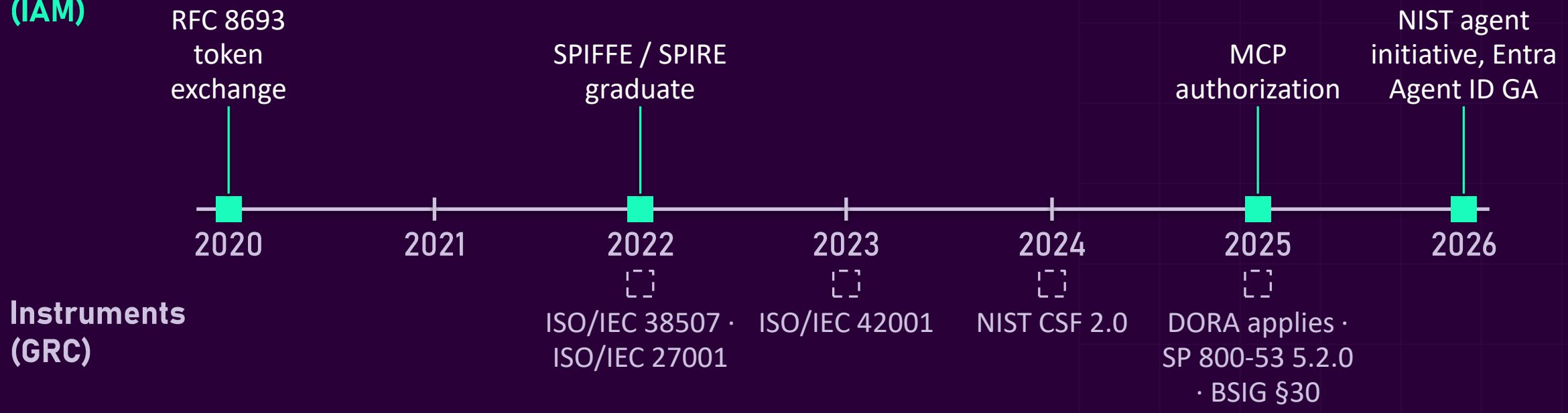
Rubric and coding workbook are public, so any cell can be re-scored:
github.com/darshan2209/bounded-agent-delegation

Method: Goswami (2026), ch. 4. Snapshot 20 Sep 2026. MITRE ATT&CK Enterprise v19.





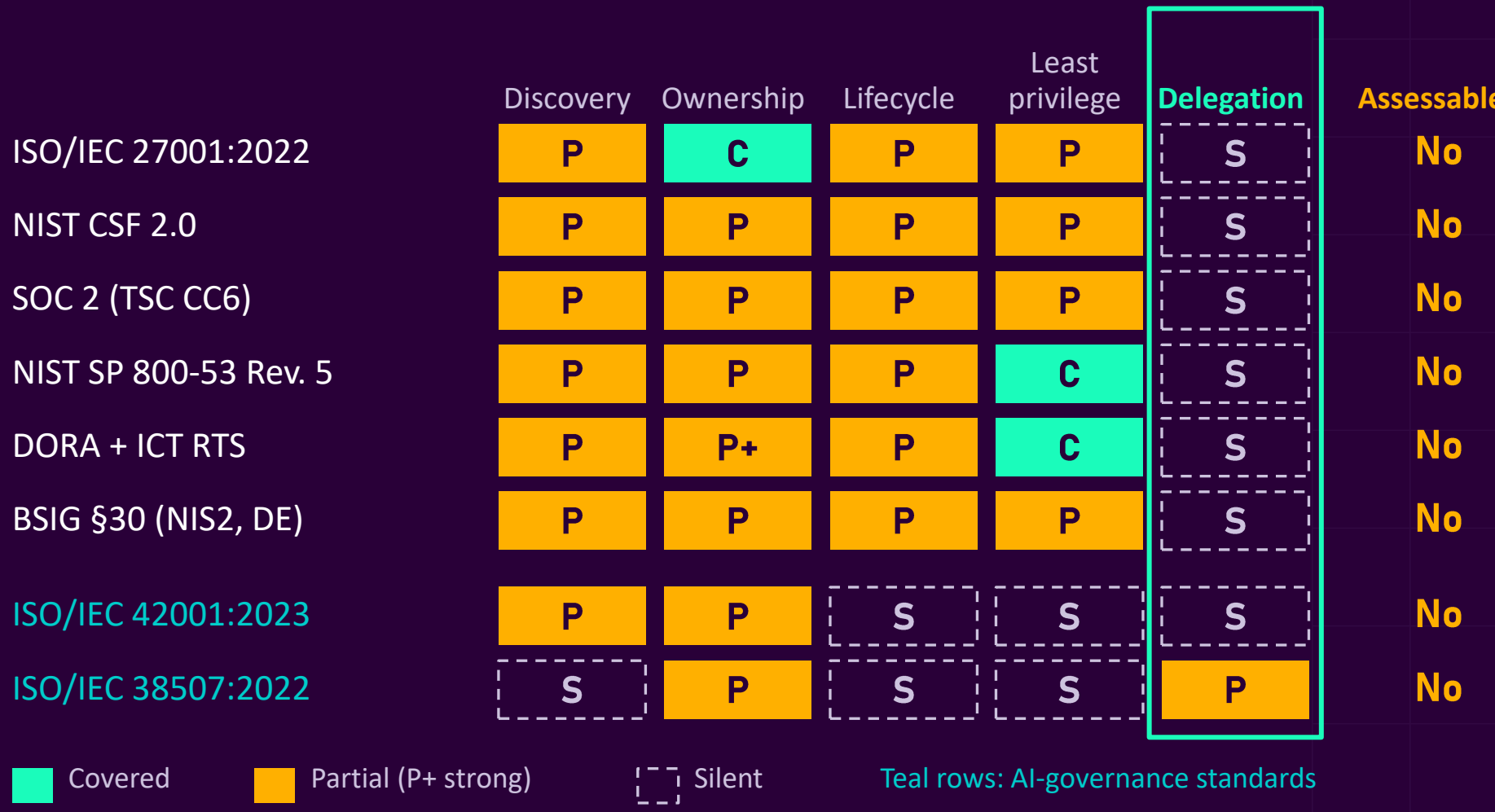
# The mechanisms shipped years ago. The mandates never followed.




Every instrument was published or revised after RFC 8693. None added a testable delegation requirement.

Sources: RFC 8693 (Jan 2020); CNCF (Aug 2022); MCP 2025-03-26; NIST (17 Feb 2026); Microsoft Entra (Apr 2026); publishers' catalogues.

# Seven of eight are silent on agent delegation. None states a testable requirement.




**7 / 8**
silent on delegation

**0 / 8**
state an assessable requirement

**3 / 40**
cells Covered

Source: Goswami (2026), Table 5.2; verdicts per the published rubric and coding workbook; snapshot 20 Sep 2026.

# Each natural objection is answered by the instrument's own text.

*“Surely the catalogue covers it?”*

**NIST SP 800-53 Rev. 5**

**IA-9 and IA-13 sit in no baseline.**

*“Surely binding law covers it?”*

**DORA RTS · BSIG §30**

**Access control, yes. Delegation, no.**

*“Surely the AI standard covers it?”*

**ISO/IEC 42001:2023**

**No access or credential category in Annex A.**

*“Surely someone has named it?”*

**ISO/IEC 38507:2022, cl. 5.1**

**Named in 2022. Then only “should”.**

Sources: NIST SP 800-53B and OSCAL baselines; Reg. (EU) 2024/1774 Arts 20, 21; BSIG §30; ISO/IEC 42001 (preview); ISO/IEC 38507 cl. 5.1.





# Silence is not neutral: each silent cell maps to a technique attackers already use.

**Delegation steps: no defence required**

| 1 | 2 | 3 | 4 | 5 |
|---|---|---|---|---|
| **T1528** | **T1550.001** | **T1078.004** | **T1552** | **T1070** |
| Steal application access token | Use application access token | Valid cloud accounts | Unsecured credentials | Indicator removal |
| Drift's OAuth tokens taken | Token replayed; no second-factor check | Bulk queries as a valid account | Exports mined; stolen data held 104 Cloudflare tokens | Query jobs deleted |
| Lifecycle · Delegation | Delegation | Discovery · Least privilege | Lifecycle | Cross-cutting |

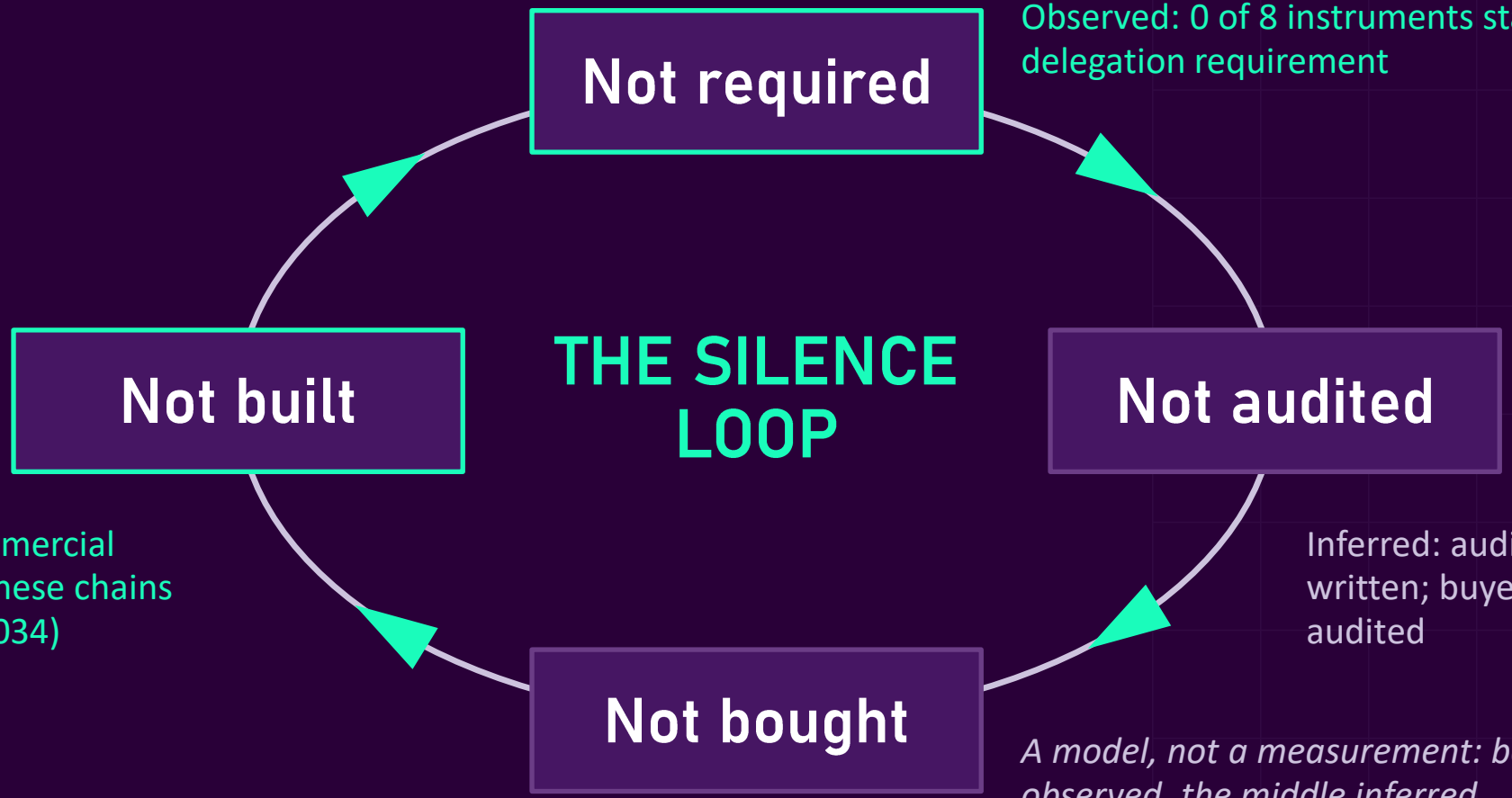
The mechanism for these steps has existed since 2020. The requirement has not.

Chain: Google GTIG (26 Aug 2025); Cloudflare (2 Sep 2025). Technique mapping: author's analysis (Goswami 2026, Table 5.3), MITRE ATT&CK Enterprise v19.





# The Silence Loop: not required, not audited, not bought, not built.




Observed: 0 of 8 instruments state an assessable delegation requirement

Inferred: auditors test what is written; buyers buy what is audited

*A model, not a measurement: both ends observed, the middle inferred.*

Observed: no commercial product governs these chains end to end (AN82034)

Sources: Goswami (2026); KuppingerCole AN82034 (10 Aug 2026).

# Break the loop at the link you control: write one “shall”.

**PROPOSAL · draft control CS-2, bounded delegation**

Where an AI agent exercises a human's access, it **shall** use a delegated credential that is least-scoped, pinned to one audience, limited to the task's lifetime, and records the actor. Implicit inheritance of standing access is prohibited.

| Least scope | One audience | Task lifetime | Actor recorded |
|---|---|---|---|
| `scope` | `aud` | `exp` | `act` |

Source: Goswami (2026), Appendix A, CS-2 (abridged). Token fields: aud, exp (RFC 7519); scope, act (RFC 8693).





# From should to shall: one clause per instrument, through routes that already exist.

~~should~~

↓

**shall**

ISO/IEC Directives: “should” is a recommendation, “shall” a requirement.

**SP 800-53B**

Allocate IA-9, plus a delegation enhancement, to the baselines

**DORA RTS, Art. 21**

Add one agent-delegation provision

**ISO/IEC 42001**

Add an access and delegation control to Annex A

Highest leverage of the eight routes (all eight: Goswami 2026, Appendix B)

Sources: ISO/IEC Directives, Part 2 (2021), cl. 7; Goswami (2026), Appendix B.





# Five things you can do on Monday, before any standard changes.

| | | |
|---|---|---|
| 1 | **Write it** | Add the “shall” to your internal control set |
| 2 | **Audit it** | Test the four bounds: scope, audience, lifetime, actor |
| 3 | **Buy it** | Ask every vendor how each delegation hop is bounded |
| 4 | **Own it** | Every agent: a named owner, an expiry, no credential over 24 hours |
| 5 | **Shape it** | Comment on the next NIST, CSA and BSI agent drafts |

24-hour threshold: KuppingerCole AN82034 (2026). NIST IR 8587 (15 Sep 2026): “NIST and CISA recognize this gap.”





# Take home three sentences.

1. Mechanisms exist. Mandates do not.
2. In identity, silence is an attack path.
3. Break the Silence Loop: write one “shall”.

# Mechanisms exist.
# Mandates do not.
# Let's write the shall.

Thank you. Where does this clause break?

**Darshangiri Goswami**

Student, Gisma University of Applied Sciences

darshangoswami22922@gmail.com

darshan2209.github.io/darshangiri-goswami

LinkedIn

# References (1 of 2)


1. Google Threat Intelligence Group (2025) Widespread Data Theft Targets Salesforce Instances via Salesloft Drift. 26 Aug 2025. cloud.google.com/blog/topics/threat-intelligence/data-theft-salesforce-instances-via-salesloft-drift
2. Cloudflare (2025) The impact of the Salesloft Drift breach on Cloudflare and our customers. 2 Sep 2025. blog.cloudflare.com/response-to-salesloft-drift-incident
3. Vercel (2026) Vercel April 2026 security incident. KB bulletin, 24 Apr 2026. vercel.com/kb/bulletin/vercel-april-2026-security-incident
4. Goswami, D. V. (2026) From Silent Controls to Exploitable Paths. MSc dissertation, Gisma University of Applied Sciences. Rubric and workbook: github.com/darshan2209/bounded-agent-delegation
5. Reinwarth, M. and Messerschmidt, P. (2026) When AI Agents Break the Security Model. Advisory Note AN82034, KuppingerCole, 10 Aug 2026. kuppingercole.com/research/an82034
6. CyberArk (2025) 2025 Identity Security Landscape (press release), 23 Apr 2025. cyberark.com/press (archived capture)
7. Entro Labs (2025) NHI & Secrets Risk Report H1 2025, 22 Jul 2025. lp.entro.security/nhi-secrets-risk-report-h1-2025
8. Sophos (2026) The State of Identity Security 2026, 12 May 2026. assets.sophos.com (report PDF)
9. Gravitee (2026) State of AI Agent Security 2026 Report, Feb 2026. gravitee.io (report PDF)
10. OpenAI (2026) OpenAI-Hugging Face Incident Technical Report, 26 Aug 2026. cdn.openai.com (report PDF)
11. Hugging Face (2026) Security incident disclosure, July 2026 (16 Jul) and Anatomy of a Frontier Lab Agent Intrusion (27 Jul). huggingface.co/blog
12. Jones, M. et al. (2020) RFC 8693: OAuth 2.0 Token Exchange. IETF, Jan 2020. rfc-editor.org/rfc/rfc8693
13. Jones, M., Bradley, J. and Sakimura, N. (2015) RFC 7519: JSON Web Token. IETF, May 2015. rfc-editor.org/rfc/rfc7519


All sources accessed or re-verified 13 Sep to 1 Oct 2026.





# References (2 of 2)


14. CNCF (2022) SPIFFE and SPIRE graduation, Aug to Sep 2022. cncf.io/projects/spiffe
15. Model Context Protocol (2025, 2026) Specification 2025-03-26 changelog; 2026-07-28 authorization. modelcontextprotocol.io
16. NIST CAISI (2026) Announcing the AI Agent Standards Initiative, 17 Feb 2026. nist.gov/news-events/news/2026/02
17. Microsoft (2026) Microsoft Entra releases and announcements: Agent ID GA (April 2026). learn.microsoft.com/entra/fundamentals/whats-new
18. NIST (2020) SP 800-53 Rev. 5 and SP 800-53B baselines; Release 5.2.0 (27 Aug 2025). csrc.nist.gov
19. European Commission (2024) Delegated Regulation (EU) 2024/1774, Arts 20 and 21. data.europa.eu/eli/reg_del/2024/1774/oj
20. BSI-Gesetz (2025) § 30, BGBl. 2025 I Nr. 301, in force 6 Dec 2025. gesetze-im-internet.de/bsig_2025/__30.html
21. ISO/IEC 42001:2023 AI management system; ISO/IEC 38507:2022 governance implications of AI (cl. 5.1); ISO/IEC 27001:2022. iso.org
22. NIST (2024) Cybersecurity Framework 2.0; AICPA (2017, rev. 2022) Trust Services Criteria (CC6).
23. ISO/IEC (2021) ISO/IEC Directives, Part 2, 9th ed., clause 7. iso.org/sites/directives/current/part2
24. MITRE (2026) ATT&CK Enterprise v19.2: T1528, T1550.001, T1078.004, T1552, T1070. attack.mitre.org
25. NIST (2026) IR 8587: Protecting Tokens and Assertions from Forgery, Theft, and Misuse. Final, 15 Sep 2026. csrc.nist.gov/pubs/ir/8587/final


All sources accessed or re-verified 13 Sep to 1 Oct 2026.



